

R20

HTB · STARTING POINT

HTB Starting Point — Crocodile

Programación para Ciberseguridad · Fase II · AD2026

Muchas aplicaciones web almacenan credenciales de acceso en archivos de texto que a veces quedan expuestos en servicios de red mal configurados. Esta máquina combina FTP anónimo (ya visto en Fawn/R14) con enumeración web — dos técnicas de Fase II que se usan juntas por primera vez.

Objetivo: Descargar una lista de credenciales expuesta vía FTP anónimo, enumerar el servidor web e iniciar sesión con las credenciales encontradas para obtener la flag.

Acceso a la plataforma

1. Inicia sesión en <https://app.hackthebox.com>, conecta la VPN de HTB.
2. Ve a Starting Point → Tier 1 → Crocodile e inicia la máquina.
3. Anota la IP asignada.

Pistas de enfoque

Escanea con `nmap -sV <IP>` para identificar los servicios activos (FTP y HTTP). Conéctate por FTP con acceso anónimo (`ftp <IP>`, usuario `anonymous`), lista los archivos con `ls` y descárgalos con `get`. Luego visita la IP en el navegador o usa `curl`, encuentra el panel de administración (pista: usa `gobuster` para enumeración de directorios si es necesario) e inicia sesión con las credenciales encontradas en el FTP.

```
gobuster dir -u http://<IP> -w /usr/share/wordlists/dirb/common.txt
```

Evidencias requeridas

- Screenshot del escaneo de `nmap` con ambos servicios (FTP y HTTP) identificados.
- Screenshot de la sesión FTP anónima con los archivos de credenciales descargados.
- Screenshot del panel de administración web y la flag obtenida.

Preguntas de reflexión

1. Esta máquina encadenó FTP anónimo (R14) con enumeración web (R15/Appointment). ¿Qué principio de seguridad ilustra el hecho de que una vulnerabilidad menor (FTP anónimo) pueda facilitar explotar otra (credenciales expuestas en web)?
2. `gobuster` enumera directorios probando palabras de un diccionario. ¿Qué inconveniente tiene ese enfoque y cuándo podría no funcionar aunque el directorio exista?
3. Has completado 4 máquinas de HTB en esta fase: Meow (Telnet), Fawn (FTP), Dancing (SMB), Redeemer (Redis), Appointment (HTTP), Sequel (MySQL) y Crocodile (FTP+HTTP). ¿Qué patrón común observas en la técnica de reconocimiento que usaste en todas ellas?